

CORPORATE POLICY

Global Procurement & Vendor Risk Management

Document ID: CORP-OPS-2026-V4

Classification: CONFIDENTIAL — Internal Use Only

Document Owner: Chief Procurement Officer (CPO)

Review Cycle: Annual | Last Reviewed: Q1 2026

Applies To: All business units, subsidiaries, and contracted staff globally

Controlled By: CPO Office in conjunction with Legal, Finance, and CISO

Supersedes: CORP-OPS-2024-V3

Queries: procurement-policy@corp.internal

SECTION 1 — FINANCIAL DELEGATION OF AUTHORITY (DoA)

All purchase requests must be triaged against the following thresholds before any vendor engagement or purchase order (PO) is raised.

Threshold A — Expedited Approval (Below \$500)

Eligible for same-day AUTO-APPROVED status only when ALL THREE of the following conditions are satisfied:

CONDITION 1 — Amount: Purchase total is below \$500.

CONDITION 2 — Vendor: Vendor is confirmed on the Approved Vendor List (AVL).

CONDITION 3 — Category: Purchase is non-software (hardware, consumables, stationery, travel).

If ANY single condition is not met, Threshold A does not apply. An unconfirmed or unknown vendor must be treated as a New Vendor regardless of purchase amount and requires VORA completion before a PO can be raised. Software purchases of any amount require IT Security sign-off regardless of vendor status or threshold.

Escalation path: None when all conditions met. Transaction logged to Cost Center Manager for monthly audit review.

Threshold B — Standard Approval (\$500 – \$10,000)

Lower boundary: \$500.00 (five hundred dollars).

Upper boundary: \$10,000.00 (ten thousand dollars).

Any amount from \$500.00 to \$10,000.00 inclusive falls under Threshold B.

Requires formal written sign-off from the Department Cost Center Manager. The purchase order must reference a valid internal budget code.

Maximum approval timeline: 3 business days.

Escalation path: If unsigned after 3 business days, the request auto-escalates to Finance Operations for review.

Threshold C — Material Expense (Above \$10,000)

Classified as a Material Expense. ALL THREE of the following are required before a PO may be raised:

REQUIREMENT 1: Procurement Board Review (minimum quorum of 3 members).

REQUIREMENT 2: Competitive 3-quote bid documentation submitted to the CPO office.

REQUIREMENT 3: CFO counter-signature for any amount exceeding \$50,000.

Absence of any single requirement puts the PO on hold until all three are satisfied.

Minimum approval timeline: 10 business days.

CPO office is notified automatically upon submission.

Split Purchase Rule

If the same requester submits two or more requests within a 7-day rolling window for the same cost category, all requests are combined and the total amount determines the applicable threshold.

Intentional splitting to circumvent thresholds is a disciplinary matter (ref: HR-POLICY-14).

SECTION 2 — DATA SOVEREIGNTY & INFORMATION SECURITY STANDARDS

All vendor engagements involving data access, storage, or processing must satisfy the following standards prior to contract execution.

Failure to satisfy a hard standard results in immediate disqualification.

Standard 2.1 — Encryption Requirements

All cloud-based solutions must implement:

- AES-256 bit encryption for data at rest
- TLS 1.2 or higher for data in transit

Failure to meet either encryption standard results in immediate REJECT status. No exceptions. No escalation path. Owner: CISO office.

Standard 2.2 — Data Residency & Sovereignty

Preference is given to vendors whose primary data centre resides within the same sovereign jurisdiction as the contracting entity. Cross-border data transfer requires a Data Transfer Impact Assessment (DTIA) approved by the Legal & Compliance team before vendor onboarding may proceed.

Regional affiliates serving entities in a different jurisdiction require Legal sign-off even where data protection frameworks are considered equivalent. Cross-border arrangements may not be auto-approved without Legal review, regardless of vendor tier or certification status.

Owner: Legal & Compliance.

Standard 2.3 — Pre-Approved Gold Tier Vendors (AVL)

The following vendors have completed full security audit and are pre-cleared for procurement subject to applicable threshold rules:

AVL VENDOR 1: NovaTech Solutions

AVL VENDOR 2: ApexCloud Corp

AVL VENDOR 3: ClearSystems Ltd

AVL VENDOR 4: BridgeCore Software

AVL VENDOR 5: PulseData Inc.

AVL VENDOR 6: VertexOps Group

AVL VENDOR 7: StellarSoft AG

AVL VENDOR 8: CoreWave Technologies

To confirm AVL status, check the vendor name against this list exactly. Partial matches or assumed matches do not constitute AVL confirmation. Any vendor NOT on this list is classified as a New Vendor and must complete the Vendor Onboarding & Risk Assessment (VORA) process before a PO can be raised, regardless of purchase amount.

VORA Exemption: Vendors providing physical goods or services with no access to company systems, networks, or data — such as catering, facilities, office supplies, or venue hire — are exempt from the VORA requirement provided ALL of the following are true:

CONDITION 1: Purchase falls within Threshold A (below \$500).

CONDITION 2: No company data, credentials, or system access is shared with the vendor.

CONDITION 3: Purchase is non-software and non-digital.

If all three conditions are met, the vendor may be treated as AVL-equivalent for Threshold A purposes only. This exemption does not apply to Threshold B or C purchases.

Standard 2.4 — Breach Notification SLA

All vendors with access to company data must provide a contractually binding 24-hour Breach Notification SLA. Absence of this clause in a vendor contract results in automatic HOLD status pending Legal review before any engagement may proceed.

Standard 2.5 — Legacy & Insecure Protocols

Vendor solutions utilising end-of-life or unencrypted protocols — including Telnet, SMBv1, FTP, or HTTP without TLS — result in immediate REJECT status. No escalation path. Owner: CISO office.

SECTION 3 — STRATEGIC EXCEPTIONS & GOVERNANCE GREY AREAS

The following rules govern scenarios where standard thresholds may be modified or where automated triage cannot produce a deterministic decision without human judgment. All exceptions must be documented and retained for 7 years per corporate records policy (ref: CORP-REC-2024).

Rule 3.1 — Professional Development & Employee Morale

Expenses for team offsites, training programmes, conferences, or employee morale events must be "Commensurate with Industry Standards" for the relevant function and seniority level.

Hard limit: Any per-head cost exceeding \$150 must be flagged for manual review by the HR Business Partner AND the Cost Center Manager before any financial commitment is made.

Owner: HR Business Partner (primary), Cost Center Manager (secondary).

Rule 3.2 — Operational Continuity & Critical Infrastructure

In cases of a declared Critical Infrastructure Failure — defined as an incident causing or likely to cause more than 4 hours of downtime on revenue-generating systems — Threshold B and Threshold C approval timelines are waived to enable rapid procurement.

Financial limits are NOT waived. A \$12,000 emergency purchase still requires Procurement Board approval; only the timeline is relaxed. The declaring authority must hold VP-level seniority or above. A full retrospective PO and audit trail is required within 5 business days of incident resolution.

Owner: CTO (incident declaration), CPO (retrospective sign-off).

Rule 3.3 — New Vendor Proof of Concept (PoC) Exception

New vendors may be engaged for a time-limited Proof of Concept under \$1,000 without completing the full VORA process only when ALL THREE of the following conditions are confirmed:

CONDITION 1 — Data: No Sensitive Personal Data (SPD) is accessed or processed during the PoC period.

CONDITION 2 — Duration: The PoC does not exceed 30 calendar days.

CONDITION 3 — Sign-off: IT Security provides lightweight written sign-off (email approval is sufficient).

If ANY condition cannot be confirmed, the PoC exception does not apply and the full VORA process is required.

SPD is defined as: customer personally identifiable information (PII), employee records, financial transaction data, health or medical data, or any data subject to GDPR, CCPA, or equivalent regulatory obligations.

If SPD involvement cannot be confirmed as absent, the PoC exception does not apply. Escalate to Legal & Compliance before proceeding. Owner: IT Security (SPD assessment), Requestor's line manager (PoC approval).

SECTION 4 — ESCALATION MATRIX & DECISION OWNERSHIP

All procurement triage decisions must result in one of the four statuses below. The agent applies this matrix after evaluating all applicable rules. Where a grey area rule is triggered, the decision is routed to the designated human reviewer within the defined SLA.

Decision Status	Trigger Criteria	Escalation Owner	SLA
AUTO-APPROVED	All policy conditions met without exception	None — auto-logged to Cost Center Manager	Same day
APPROVED — PENDING SIGN-OFF	Policy rules fully resolve the case and the request is approvable in principle. One or more required signatures, documented approvals, or procedural steps are outstanding. No	Cost Center Manager / Procurement Board/ CFO (per threshold)	3–10 business days

	judgment call required.		
FLAGGED — HUMAN REVIEW	Policy rules apply but require subjective judgment to reach a decision. Examples: ambiguous criteria, undefined standards, or scenarios the policy does not explicitly resolve. Note: missing signatures or pending approvals are NOT a basis for this status — use APPROVED — PENDING SIGN-OFF for those cases.	Policy section owner as designated within the relevant section	2 business days
REJECTED	A mandatory technical or compliance standard is not satisfied	CISO — no escalation path	Immediate

Any queries regarding the interpretation of this policy should be directed to the CPO office at: procurement-policy@corp.internal Unauthorised amendments to this document constitute a disciplinary offence under HR-POLICY-14. Retain for 7 years per CORP-REC-2024.